



Amministratore Delegato e Direttore Generale

COMUNICAZIONE ORGANIZZATIVA n. 529/AD del 19 sett 2019

“Linee di indirizzo per la gestione del Data Breach”

Con la presente Comunicazione Organizzativa, che recepisce la CO/G n. 20/CRO/DPO del 29 gennaio 2019, vengono emanate le Linee di indirizzo per la gestione del Data Breach”, che sono riportate in allegato e ne costituiscono parte integrante a tutti gli effetti.

Tali Linee di indirizzo rientrano nell’ambito del Framework di Data Protection così come definito con la DdG n.252/AD del 10 maggio 2018 e recepita in Trenitalia SpA con la CO n. 518/AD del 1 mar 2019.

FIRMATO
Orazio Iacono

Allegato alla CO n.529/AD del 19 sett 2019

Linee di indirizzo per la gestione del Data Breach

1 Premessa

1.1 Contesto normativo

Il 27 aprile 2016, il Parlamento ed il Consiglio dell'Unione Europea ("UE" nel seguito) hanno approvato un'importante riforma del quadro normativo relativo alla tutela dei dati personali adottando un pacchetto di riforme¹ che comprende il Regolamento UE 2016/679 "*Regolamento generale sulla protezione dei dati*" (nel seguito "GDPR" o "Regolamento").

Il Decreto Legislativo 10 agosto 2018 n. 101, recante norme per l'adeguamento della normativa nazionale al Regolamento UE n. 679/2016, ha conseguentemente modificato le disposizioni del Codice in materia di protezione dei dati personali D. Lgs. n. 196/2003.

Il Regolamento introduce il concetto di "**violazione dei dati personali**" (nel seguito per "*Data breach*") si fa riferimento esclusivamente a violazioni che riguardino Dati Personali² e non ad altre tipologie di informazioni) ossia la violazione di sicurezza che comporta accidentalmente o in modo illecito³ la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati personali trasmessi, conservati o comunque trattati. In particolare secondo quanto previsto dal WP250 "*Guidelines on Personal data breach notification under Regulation 2016/679*", gli eventi di possibile violazione dei dati personali possono essere suddivisi in tre macro categorie:

- "**Violazione di confidenzialità**": in caso di divulgazione dei dati personali o accesso agli stessi non autorizzati o accidentali ;
- "**Violazione di disponibilità**": in caso di perdita, accesso o distruzione accidentali o non autorizzati di dati personali⁴;
- "**Violazione di integrità**": in caso di alterazione non autorizzata o accidentale dei dati personali.

Una violazione può riguardare contemporaneamente la confidenzialità, l'integrità e la disponibilità dei dati personali, nonché qualsiasi combinazione delle stesse.

Il Regolamento specifica, all'Art. 33, che il Titolare **notifica** la violazione all'autorità di controllo competente senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui ne sia venuto a conoscenza, a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche, nel qual caso la notifica non è dovuta. Una notifica effettuata oltre il termine delle 72 ore deve essere corredata dai motivi del ritardo.

¹ Il pacchetto di riforme in materia di tutela dei dati personali approvato dall'Unione Europea comprende: (i) il Regolamento (UE) 2016/679 (GDPR) del Parlamento europeo e del Consiglio relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati e che abroga la direttiva 95/46/CE; (ii) la Direttiva (UE) 2016/680 del Parlamento europeo e del Consiglio relativa alla protezione delle persone fisiche con riguardo al trattamento dei dati personali da parte delle autorità competenti a fini di prevenzione, indagine, accertamento e perseguimento di reati o esecuzione di sanzioni penali, nonché alla libera circolazione di tali dati e che abroga la decisione quadro 2008/977/GAI del Consiglio.

² Cfr. Par. 2.1 Definizioni

³ Un trattamento non autorizzato o illecito può includere la divulgazione di dati personali a (o l'accesso da parte di) destinatari non autorizzati a ricevere (o ad accedere a) i dati oppure qualsiasi altra forma di trattamento in violazione del regolamento.

⁴ L'indisponibilità dei dati personali dovuta allo svolgimento di un intervento di manutenzione programmata del sistema non costituisce una "violazione della sicurezza".

Inoltre, a norma dell'art. 34 del Regolamento, quando la violazione dei dati personali potrebbe determinare un rischio elevato per i diritti e le libertà delle persone fisiche, il Titolare **comunica la violazione all'interessato** senza ingiustificato ritardo⁵.

È parimenti obbligo del Responsabile informare il Titolare senza ingiustificato ritardo dopo essere venuto a conoscenza della violazione. Nel caso in cui Trenitalia SpA in qualità di Titolare del trattamento abbia affidato dei servizi, che comportino trattamento di dati personali, ad una Terza Parte (anche nelle ipotesi di contratti infragruppo), quest'ultimo dovrà segnalare senza ingiustificato ritardo alla Società Titolare del trattamento, eventuali casi di *Data breach* secondo quanto previsto dagli artt. 33 e 34, ed in funzione degli accordi di *data protection* stipulati secondo le linee di indirizzo per la gestione delle Terze Parti. Tale obbligo di informativa senza ingiustificato ritardo nei confronti del Titolare ricade anche su Trenitalia SpA che tratti dati personali di una Terza Parte (anche nelle ipotesi di contratti infragruppo) in qualità di Responsabile. Qualora fornisca servizi a più titolari del trattamento tutti interessati dal medesimo incidente, il Responsabile del trattamento dovrà segnalare i dettagli dell'incidente a ciascun titolare del trattamento. In ipotesi di contitolarità il (con)titolare del trattamento assumerà il comando o sarà responsabile del rispetto degli obblighi di notifica delle violazioni previsti dal regolamento in base a quanto stabilito a tal riguardo dal relativo accordo di *data protection*.

1.2 Contenuti del Documento

Il documento disciplina le regole e le indicazioni operative per individuare le violazioni dei dati personali e per garantire il governo e l'attuazione del processo di gestione dei *Data breach* all'interno Trenitalia SpA, nonché i ruoli e responsabilità delle figure organizzative chiave coinvolte.

Il documento si inquadra all'interno delle Linee di Indirizzo in materia di *Data protection* emanate dalla Capogruppo con DdG n. 252/AD in data 10 maggio 2018, recepita in Trenitalia con la CO 518/AD del 1° marzo 2019, a cui si rimanda per la definizione del Modello di *Data protection*.

1.3 Destinatari e Modalità di Recepimento

Nel rispetto della piena autonomia societaria, la presente Comunicazione Organizzativa recepisce – d'intesa con il *Data Protection Officer* di FS SpA- le linee di indirizzo per la gestione *data breach* emanate dalla Capogruppo con Comunicazione Organizzativa n. 20/CRO/DPO del 29.01.2019 "Linee di indirizzo per la gestione dei *data breach*" e le declina nel contesto di Trenitalia SpA.

Le procedure descritte in questo documento si applicano a tutti coloro che partecipano attivamente alla progettazione o all'esecuzione di un trattamento di dati personali, anche avvalendosi di terze parti rispetto alla Società, incluse le terze parti appartenenti al Gruppo FS

⁵ La comunicazione all'interessato non è richiesta se è soddisfatta una delle seguenti condizioni:

a) il titolare del trattamento ha messo in atto le misure tecniche e organizzative adeguate di protezione e tali misure erano state applicate ai dati personali oggetto della violazione, in particolare quelle destinate a rendere i dati personali incomprensibili a chiunque non sia autorizzato ad accedervi, quali la cifratura;

b) il titolare del trattamento ha successivamente adottato misure atte a scongiurare il sopraggiungere di un rischio elevato per i diritti e le libertà degli interessati;

c) detta comunicazione richiederebbe sforzi sproporzionati. In tal caso, si procede invece a una comunicazione pubblica o a una misura simile, tramite la quale gli interessati sono informati con analoga efficacia.

Nel caso in cui il titolare del trattamento non abbia ancora comunicato all'interessato la violazione dei dati personali, l'autorità di controllo può richiedere, dopo aver valutato la probabilità che la violazione dei dati personali presenti un rischio elevato, che vi provveda o può decidere che una delle summenzionate condizioni è soddisfatta.

Italiane (per esempio nel caso in cui i trattamenti siano svolti in *service* da un'altra Società del Gruppo).

A seguito di eventuali modifiche all'assetto societario di Gruppo (acquisizione, fusione, scorporo etc.), le "nuove" entità legali, sono soggette al recepimento della presente e ad avviare tutte le attività necessarie per un pronto adeguamento.

1.4 Documenti correlati

Documento	Nome
DdG n.252/AD del 10 mag 2018	Linee di Indirizzo in materia di <i>Data Protection</i>
CO n.518/AD del 1 mar 2019	Gestione Sistema Data Protection in Trenitalia SpA
CO n.519/AD del 1 mar 2019	Designazione delle Persone autorizzate al Trattamento dei Dati Personali
CO n.525/AD del 19 sett 2019	Gestione delle Terze Parti
CO n.526/AD del 19 sett 2019	Gestione dei diritti degli Interessati
CO n.527/AD del 19 sett 2019	Identificazione dei Trattamenti a potenziale rischio elevato e DPIA
CO n.528/AD del 19 sett 2019	Data Protection By Design e By Default
CO/G n.6/CRO/DPO del 25 giu 2018	Linee di Indirizzo per la gestione delle Terze Parti con riferimento alla protezione dei dati personali
CO/G n.8/CRO/DPO del 24 lug 2018	Linee di indirizzo per la gestione dei diritti degli interessati
CO/G n.11/CRO/DPO del 26 sett 2018	Linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e DPIA
CO/G n.12/CRO/DPO del 26 sett 2018	Linee di indirizzo per la Data Protection By Design e By Default
CO/G n.20/CRO/DPO del 26 gen 2019	Linee di indirizzo per la gestione dei Data Breach

2 Figure Chiave e Definizioni

2.1 Sintesi delle figure chiave e delle responsabilità

Figura Chiave	Descrizione Figura e Responsabilità
<i>Titolare</i>	La persona fisica, giuridica, la pubblica amministrazione e qualsiasi altro ente, associazione od organismo cui competono, anche unitamente ad altro Titolare (Contitolare), le decisioni in ordine alle finalità, alle modalità del trattamento dei dati personali ed agli strumenti utilizzati, ivi compreso il profilo della sicurezza. Nell'ambito del Trenitalia SpA la figura del Titolare è rappresentata dall'AD delle Società, su delibera dei rispettivi CdA. Nei casi di contitolarità devono essere formalizzate le rispettive responsabilità. Al Titolare è affidata la responsabilità ultima della corretta gestione delle violazioni dei dati personali dei soggetti interessati.
<i>Data Manager</i>	Il responsabile della struttura organizzativa macro che, in relazione alle attività assegnate, è designato dal Titolare al trattamento di dati personali. Il <i>Data Manager</i> ha la responsabilità di progettare i trattamenti di dati personali che derivano da esigenze di <i>business</i>/operative in modo da garantire nativamente il rispetto dei principi del Regolamento e, allo stesso tempo, circoscrivere e limitare l'utilizzo di dati personali. Il <i>Data Manager</i> è la figura che supporta il gruppo di lavoro nell'identificazione degli elementi utili alla notifica all'Autorità Garante o la comunicazione agli interessati.
<i>Data Protection Officer (DPO) di Capogruppo e societario</i>	Il soggetto i cui compiti sono stabiliti dall'articolo 39 del Regolamento, nelle Linee Guida del Gruppo "<i>Article 29 Data protection Working Party</i>" e nel seguito del presente documento. Il DPO societario recepisce e contestualizza quanto emanato dal DPO di Capogruppo, coordinandosi con lo stesso per indirizzare le attività in ambito Data Protection. Il DPO di Capogruppo ha infatti il compito di definizione delle metodologie, di indirizzo e coordinamento delle attività. Il DPO societario e il DPO di Capogruppo fungono da punto di contatto con l'Autorità di controllo, ciascuno nei limiti delle proprie competenze. È nominato, su proposta dell'AD (Titolare), dal CdA, a cui riporta funzionalmente. Il DPO di Capogruppo, tramite la presente procedura, definisce le regole per la gestione dei <i>Data breach</i>. Il DPO societario riceve le segnalazioni di potenziali <i>Data breach</i>, identifica se si tratta effettivamente di una violazione dei dati personali e, in caso positivo, procede alla predisposizione del <i>Data breach Report</i>. In base alla valutazione del livello di gravità del <i>Data breach</i> procede con l'eventuale notifica all'Autorità Garante e con la comunicazione agli interessati.

Figura Chiave	Descrizione Figura e Responsabilità
<i>Computer Security Incident Response Team (CSIRT)</i>	Gruppo di gestione degli incidenti di sicurezza informatica costituito all'interno della Struttura <i>Cyber Security</i> di FS SpA.
<i>Direzione Centrale Chief Risk Officer di FS SpA</i>	La Struttura assicura il supporto ed il coordinamento metodologico delle attività di identificazione, analisi, misurazione, valutazione e monitoraggio dei rischi per il Gruppo, a complemento delle valutazioni di impatto per i diritti e le libertà degli interessati svolte dal <i>Data Protection Officer</i> .
<i>Referente Data Protection</i>	Il Referente per la <i>Data Protection</i> è il soggetto aziendale, con competenze in ambito <i>Data Protection</i>, che supporta il Titolare e i <i>Data Manager</i> nelle attività operative di adempimento normativo. Funge da punto di riferimento per il DPO societario. È nominato dal Titolare. Supporta il DPO societario e di Capogruppo in tutte le fasi relative al processo di gestione dei <i>Data breach</i>.
<i>FS Technology</i>	Società del Gruppo FS Italiane deputata allo sviluppo e all'esercizio dei Sistemi IT di Gruppo. Nell'ambito del presente documento è il soggetto tecnico di riferimento che, raccolte le esigenze del <i>Data Manager</i> in materia di periodi e criteri di conservazione, garantisce l'allineamento degli applicativi IT e l'implementazione dei meccanismi (automatici o manuali) di cancellazione, anonimizzazione o revisione del dato personale.
<i>Strutture segnalanti</i>	Qualsiasi Struttura di Trenitalia SpA che rilevi, anche per il tramite di collaboratori esterni, clienti e fornitori, un potenziale <i>Data breach</i> . Tali strutture reindirizzano le segnalazioni al DPO societario.
<i>Gruppo di Lavoro</i>	Gruppo di lavoro interfunzionale convocato dal DPO societario, al fine di comprendere la natura del <i>Data Breach</i>, valutare il livello di gravità della violazione e procedere con eventuali comunicazioni agli interessati, con la notifica all'Autorità Garante per la Protezione dei Dati Personali e con la definizione del <i>Remediation Plan</i>. Il Gruppo di Lavoro è composto dal DPO di Capogruppo, dal DPO di societario, il/i <i>Data Manager</i> coinvolti, il Referente Data Protection, il Responsabile per il Sistema Informativo individuato in FS Technology e <i>Cyber Security</i> di FS SpA (nel caso di <i>data breach</i> legato alla violazione dei Sistemi IT) e, ove necessario per supporto specialistico, la DALS⁶ e le Strutture Legali societarie. In funzione della gravità del <i>data breach</i>, il Gruppo di Lavoro può essere esteso ad altre strutture aziendali.

⁶ Nelle more della definizione della funzione di *Compliance* aziendale

2.2 Definizioni

Oggetto	Definizione
<i>Data breach</i>	All'interno di Trenitalia SpA, si intende per <i>data breach</i> una violazione di sicurezza che comporta, accidentalmente o in modo illecito, le seguenti tipologie di eventi (a titolo esemplificativo e non esaustivo) aventi ad oggetto “dati personali”: ▪ distruzione di dati personali su supporti digitali o cartacei, intesa come indisponibilità irreversibile di dati con accertata impossibilità di ripristino degli stessi, conseguente ad eliminazione logica (es. errata cancellazione dei dati nel corso di un intervento manuale o automatizzato) o fisica (es. rottura di dispositivi di memorizzazione informatica, incendio/allagamento locali dove sono archiviati i contratti ed altri documenti dei clienti); ▪ perdita di dati personali, conseguente a smarrimento/furto di supporti digitali (es. <i>laptop</i>, <i>hard-disk</i>, <i>memory card</i>) o cartacei (in originale o in copia); ▪ accesso non autorizzato o intrusione nei Sistemi IT, mediante lo sfruttamento di vulnerabilità dei sistemi e delle reti o la compromissione o rilevazione abusiva di credenziali di autenticazione (es. <i>userid</i> e <i>password</i>); ▪ modifica non autorizzata di dati personali, derivante ad esempio da un'erronea esecuzione di interventi sui sistemi digitali o cartacei o da interventi intenzionali non autorizzati; ▪ diffusione di dati personali a soggetti terzi non autorizzati, anche non identificati, conseguenti ad esempio alla diffusione verbale, ad invio intenzionale o accidentale di documenti o errata gestione di supporti digitali.
<i>Dato(i) Personale(i)</i> / <i>Interessato</i>	Qualsiasi informazione riguardante una persona fisica identificata o identificabile (di seguito, “Interessato”); si considera identificabile la persona fisica che può essere identificata, direttamente o indirettamente, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all'ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale.
<i>Trattamento</i>	Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali, come la raccolta, la registrazione, l'organizzazione, la strutturazione, la conservazione, l'adattamento o la modifica, l'estrazione, la consultazione, l'uso, la comunicazione mediante trasmissione, diffusione o qualsiasi altra forma di messa a disposizione, il raffronto o l'interconnessione, la limitazione, la cancellazione o la distruzione.
<i>Registro delle Violazioni di Dati</i>	Il supporto informatico che consente al Titolare di documentare

Oggetto	Definizione
Personalità	“qualsiasi violazione dei dati personali, comprese le circostanze a essa relative, le sue conseguenze e i provvedimenti adottati per porvi rimedio.” (art. 33, par. 5, GDPR). Le informazioni contenute nel Registro sono stabilite dal DPO di Capogruppo, secondo il <i>template</i> riportato sulla intranet aziendale. Scopo del Registro è quello di consentire all'Autorità Garante di verificare, in caso di ispezione o richiesta di specifica, il rispetto degli adempimenti in capo al Titolare nella gestione delle violazioni dei dati personali e fornire un utile strumento per la mitigazione del <i>data breach</i> e il seguimento delle attività di <i>Remediation</i>.

3 Il processo di gestione dei *Data breach*

Trenitalia S.p.A. ha definito un processo strutturato di *data breach Management* con l'obiettivo di gestire le segnalazioni di potenziali violazioni di dati personali e confermare o meno che si tratti di un *data breach*; in questo ultimo caso, il processo guida nella valutazione della gravità dell'evento al fine di stimare il potenziale rischio per i diritti e le libertà degli interessati. Tale valutazione è necessaria al fine di stabilire se procedere o meno con la notifica all'Autorità Garante ed eventualmente agli interessati coinvolti.

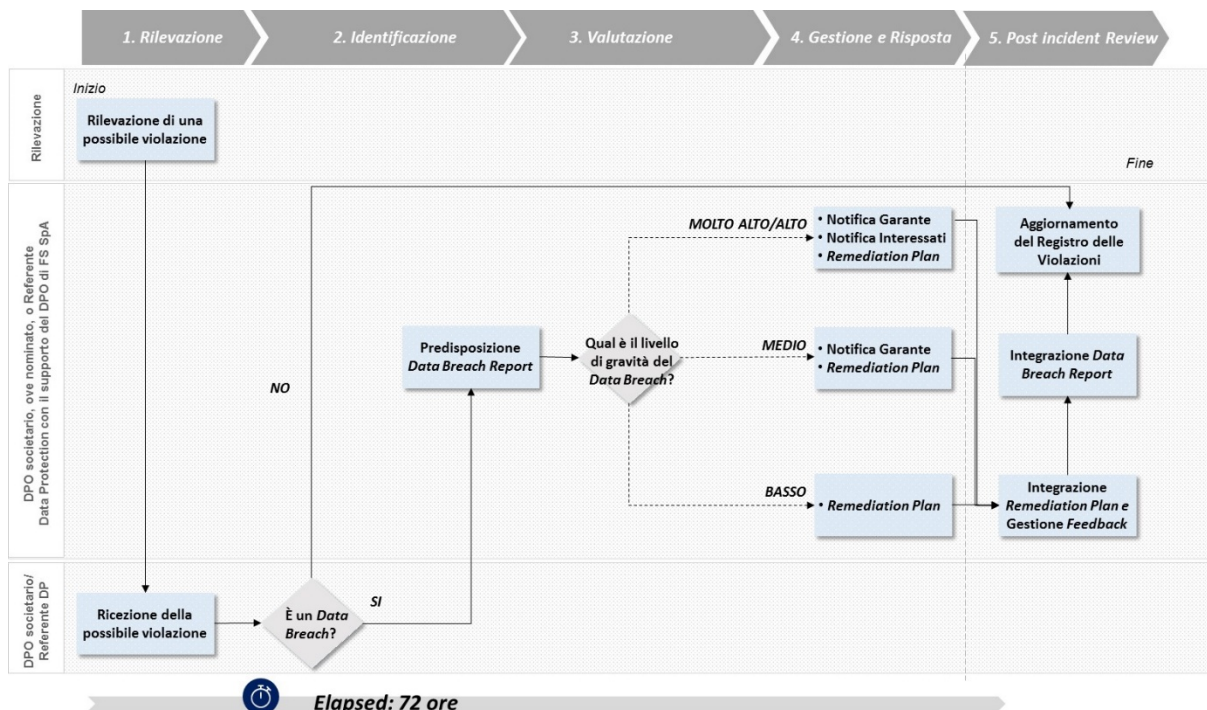
Il processo di *Data Breach Management* disciplina, inoltre, la creazione del Registro delle Violazioni di Dati Personali e le azioni di *Remediation* per il contenimento degli impatti sugli interessati e il rafforzamento delle misure esistenti.

Ogni violazione dei dati personali, occorsa all'interno di Trenitalia SpA, deve essere gestita in linea con quanto previsto nelle fasi descritte di seguito:

1. **Rilevazione:** fase di individuazione di un potenziale data breach e di tempestiva segnalazione al DPO societario.
2. **Identificazione:** fase in cui la segnalazione ricevuta viene identificata come un data breach o come altro incidente di sicurezza (falso positivo); se si tratta di data breach, viene predisposto il Data Breach Report con tutte le informazioni al momento disponibili.
3. **Valutazione:** fase di valutazione della gravità del data breach, sulla base del Report predisposto, con riferimento ai diritti e libertà degli interessati coinvolti. In questa fase viene, inoltre, valutato l'impatto del data breach per le Società del Gruppo FS Italiane coinvolte.
4. **Gestione e risposta:** in base al livello di gravità del data breach, il Titolare dovrà comunicare la violazione agli interessati e/o all'Autorità Garante; inoltre, in tale fase viene definito il Remediation Plan al fine di porre rimedio alla violazione e per attenuarne i possibili effetti negativi. In questa fase viene, inoltre, valutata la necessità di attivazione di eventuali piani di crisis management.
5. **Post Incident Review:** fase conclusiva di integrazione del Data Breach Report e di analisi ex post della violazione al fine di comprendere le root causes⁷, le lesson learned⁸ e le opportunità di miglioramento.

⁷ Root Causes: fattori causali di base dell'incidente

Di seguito il diagramma di flusso del processo di gestione delle violazioni dei dati personali.



3.1 Fase 1: Rilevazione

Qualsiasi struttura di Trenitalia S.p.A. che rilevi, anche per il tramite di collaboratori esterni, clienti e fornitori, un potenziale *data breach*, è tenuta a dare tempestiva comunicazione al DPO societario (protezionedati@trenitalia.it) e al DPO di FS SpA (protezionedati@fsitaliane.it).

La rilevazione di un potenziale *data breach* può avvenire attraverso:

- Rilevazione da parte di terze parti esterne a Trenitalia SpA (ad esempio, Responsabili del trattamento/Contitolari/altri Titolari Autonomi, interessati, associazioni di categoria, Forze dell'Ordine, Autorità di Controllo, etc.).
- Rilevazione diretta da parte di Trenitalia SpA (ad esempio, un dipendente che si rende conto di aver smarrito un faldone).
- Sistemi di monitoraggio della sicurezza informatica del Gruppo FS Italiane (*Cyber Security* di FS SpA).

Stante il limitato arco temporale a disposizione del DPO per gestire e comunicare l'eventuale *data breach* (72 ore solari dalla ricezione della segnalazione) tutte le strutture che rilevano un potenziale *data breach* sono tenute a segnalarlo senza ingiustificato ritardo e, possibilmente, entro 2 ore dalla scoperta.

⁸ *Lesson Learned*: esperienza acquisita dopo l'incidente

3.2 Fase 2: Identificazione

Il DPO societario valuta la segnalazione ricevuta, interessando tutte le Strutture necessarie alla piena comprensione dell'evento e informando contestualmente il DPO di Capogruppo.

Possono verificarsi i seguenti casi:

- l'evento segnalato non si configura come un *data breach* (cd. **falso positivo**): il DPO societario aggiorna in tal senso il Registro delle Violazioni di Dati Personali (secondo il modello predisposto dal DPO di Capogruppo riportato sulla intranet aziendale), informandone il DPO di Capogruppo;
- l'evento segnalato si configura come un *data breach* non legato alla violazione dei Sistemi IT (ad es. furto di un faldone contenente documentazione cartacea e pubblicazione *online*): il DPO societario, in collaborazione con le strutture interessate, raccoglie tutte le informazioni necessarie alla piena comprensione dell'evento.
- l'evento segnalato si configura come un *data breach* legato alla violazione dei Sistemi IT (ad es. esfiltrazione di dati a seguito di attacco informatico): *Cyber Security* di FS SpA (mediante il proprio *Computer Security Incident Response Team*) provvede ad attivare le procedure adottate dal Gruppo FS Italiane in materia di gestione degli incidenti di sicurezza informatica, coinvolgendo il DPO di Capogruppo, il DPO societario e il Responsabile della struttura individuata in FS Technology.

3.3 Fase 3: Valutazione

Sulla base delle informazioni raccolte nella fase precedente, nel caso in cui l'evento segnalato si configuri come un *data breach*, il DPO societario convoca un Gruppo di Lavoro composto dal DPO societario stesso e dal DPO di Capogruppo, dal Referente Data Protection, il/i *Data Manager* coinvolti, il Responsabile della struttura individuata in FS Technology, *Cyber Security* di FS SpA (nel caso di *data breach* legato alla violazione dei Sistemi IT) e, ove necessario per supporto specialistico, la *DALS*⁹ di Trenitalia SpA, e le strutture legali societarie¹⁰.

Il Gruppo di Lavoro così definito valuta la "magnitudo" del *data breach* mediante la "Metodologia di valutazione della gravità di un *Data breach*" disponibile sulla intranet aziendale, stimando il potenziale rischio per i diritti e le libertà delle persone fisiche.

All'esito di questa fase, il livello di gravità del *data breach* potrà essere:

Livello	Descrizione
Basso	Il dato personale oggetto di <i>data breach</i> è tale per cui gli interessati non incontrano inconvenienti o incontrano inconvenienti poco significativi, che supereranno senza particolari difficoltà (visualizzazione di dati di contatto da parte di soggetti non interessati commercialmente agli stessi dati, tempo trascorso a reinserire informazioni accidentalmente cancellate, altri disagi minori, etc.).
Medio	Gli interessati potrebbero incontrare taluni disagi, che saranno in grado di

⁹ Nelle more della definizione della funzione di *Compliance* aziendale

¹⁰ Se necessario, il DPO societario può estendere la composizione del Gruppo di Lavoro ad altre Strutture necessarie per la piena comprensione dell'evento.

	superare nonostante alcune difficoltà (costi aggiuntivi, rifiuto di accesso ai servizi aziendali, paura, discriminazione lieve, stress, etc.).
Alto	Gli interessati potrebbero incontrare conseguenze significative, che dovrebbero essere in grado di superare anche se con gravi difficoltà (inserimento in <i>black-list</i> , danni alla proprietà, perdita di posti di lavoro, citazione in giudizio, peggioramento delle condizioni di salute, etc.).
Molto Alto	Gli interessati potrebbero incontrare conseguenze significative, o addirittura irreversibili, che difficilmente riescono a superare (difficoltà finanziarie, incapacità lavorativa, disturbi psicologici o fisici a lungo termine, gravi lesioni o morte, etc.).

Il DPO societario, sulla base delle informazioni raccolte e della valutazione di magnitudo del *data breach*, predispone il *Data Breach Report* secondo il modello fornito dal DPO di Capogruppo e riportato sulla intranet aziendale.

Il DPO societario informa il DPO di Capogruppo che, sulla base della magnitudo del *data breach*, del numero di interessati coinvolti, delle possibili sanzioni e dei potenziali risvolti reputazionali, informa la direzione centrale *Chief Risk Officer* di FS SpA affinché sia coinvolta nella valutazione dell'impatto per le Società interessate dal *data breach*.

3.4 Fase 4: Gestione e risposta

In base al livello di gravità del *data breach*, il DPO societario – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso – dovrà, eventualmente, procedere con:

- la notifica al Garante per la Protezione dei Dati Personali;
- la comunicazione agli interessati coinvolti,

secondo le regole sintetizzate in tabella:

Livello	Notifica al Garante Privacy [ove possibile entro le 72 ore]	Comunicazione agli interessati [senza ingiustificato ritardo]
Basso	NO	NO
Medio	SI	NO
Alto	SI	SI
Molto Alto	SI	SI

3.4.1 Notifica al Garante per la Protezione dei Dati Personali

A norma dell'Art. 33 del Regolamento è prevista la notifica della violazione all'Autorità Garante senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui il Titolare ne sia venuto a conoscenza, ossia dal momento in cui è ragionevolmente certo che si è verificato un incidente di sicurezza che ha portato alla compromissione dei dati personali¹¹, a meno che sia

¹¹ Se un soggetto informa il titolare del trattamento di una potenziale violazione o se egli stesso rileva un incidente di sicurezza, il titolare del trattamento può effettuare una breve indagine per stabilire se la violazione si sia effettivamente verificata. Durante il

improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche.

Previa condivisione del *Data Breach Report* e degli esiti relativi alla Valutazione di Impatto con il Titolare del trattamento, il DPO societario – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso – procede alla notifica all'Autorità Garante, attraverso la procedura resa disponibile dal Garante per la Protezione dei Dati personali stesso sul proprio sito web¹² ed inserendo le seguenti informazioni¹³:

- **Natura della violazione dei dati personali** compresi, ove possibile, le categorie e il numero approssimativo di interessati in questione nonché le categorie e il numero approssimativo di registrazioni dei dati personali in questione.
- **Nome e i dati di contatto del DPO o del Referente *Data Protection*** presso cui ottenere più informazioni.
- **Probabili conseguenze della violazione dei dati personali.**
- **Descrizione delle misure adottate o di cui si propone l'adozione** per porre rimedio alla violazione dei dati personali e anche, se del caso, per attenuarne i possibili effetti negativi.

Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni dovranno essere fornite in fasi successive senza ulteriore ingiustificato ritardo.

3.4.2 Comunicazione agli interessati

Qualora la magnitudo del *data breach* presenti un rischio **alto** o **molto alto** per i diritti e le libertà degli interessati, il DPO societario – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso – dovrà valutare se ricorre uno dei seguenti casi (ai sensi dell'Art. 34, Par. 5, del Regolamento):

1. sono state adottate preventivamente dal Titolare misure tecniche e organizzative adeguate di protezione e tali misure erano state applicate ai dati personali oggetto della violazione, in particolare quelle destinate a rendere i dati personali incomprensibili a chiunque non sia autorizzato ad accedervi, quali la **cifratura**;
2. il Titolare ha adottato misure successive alla violazione che garantiscano la riduzione del rischio ad un livello considerato come medio o basso per i diritti e le libertà degli interessati;
3. la comunicazione all'interessato comporta sforzi sproporzionati.

Nei casi 1. e 2. non dovrà essere effettuata alcuna comunicazione agli interessati; nel caso 3. il DPO societario – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso e d'intesa con la Direzione Centrale Media e con la struttura Relazioni Esterne di FS SpA – valuterà una modalità consona per darne comunicazione pubblica in modo tale che gli interessati vengano informati in modo efficace.

Nel caso in cui non ricorrano i punti 1. 2. e 3., il DPO societario – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso e d'intesa con la Direzione Centrale Media e con

periodo di indagine il titolare del trattamento non può essere considerato "a conoscenza". Tuttavia, si prevede che l'indagine iniziale inizi il più presto possibile e stabilisca con ragionevole certezza se si è verificata una violazione; può quindi seguire un'indagine più dettagliata.

¹² Qualora la procedura on line non sia disponibile, la notifica avverrà via mail all'indirizzo garante@spdp.it

¹³ Il Legislatore Europeo ha indicato le informazioni minimali che devono essere previste nelle notifiche. Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni possono essere fornite in fasi successive senza ulteriore ingiustificato ritardo.

Relazioni Esterne di FS SpA – informerà il Titolare del Trattamento e, autorizzato dal medesimo, darà comunicazione agli interessati senza ingiustificato ritardo tramite e-mail e/o lettera raccomandata. La comunicazione all'Interessato viene effettuata fornendo le seguenti informazioni e secondo le seguenti modalità¹⁴:

- **Descrizione** con linguaggio semplice e chiaro **circa la natura della violazione dei dati personali**.
- **Nome e i dati di contatto del DPO** o di altro punto di contatto presso cui ottenere più informazioni.
- **Probabili conseguenze della violazione dei dati personali**.
- **Descrizione delle misure adottate o di cui si propone l'adozione** per porre rimedio alla violazione dei dati personali e anche, se del caso, per attenuarne i possibili effetti negativi.

Nel comunicare una violazione agli interessati si devono utilizzare messaggi dedicati che non devono essere inviati insieme ad altre informazioni, quali aggiornamenti regolari, newsletter o messaggi standard¹⁵.

3.4.3 Remediation Plan

Il DPO societario, in funzione della tipologia di violazione, interessa il Gruppo di Lavoro al fine di definire un piano di rimedio alla violazione e attenuarne i possibili effetti negativi. Ad esempio, la funzione IT individuata in FS Technology attiva apposite misure di *remediation* finalizzate a proteggere gli asset soggetti a violazione, la funzione di Protezione Aziendale informa eventualmente le autorità competenti nel caso di furto di un asset, la funzione di Organizzazione rivede le procedure di archiviazione di alcune tipologie di dati, etc.

3.4.4 Attivazione delle procedure di crisis management

Nel caso in cui la violazione determini un impatto rilevante per una o più delle Società del Gruppo FS Italiane, il DPO societario, – sentito il *Data Protection Officer* di Capogruppo e coordinandosi con lo stesso – attiva, ove definite, eventuali procedure di *crisis management* esistenti all'interno dell'organizzazione. In ogni caso, in presenza di un rilevante impatto reputazionale, il DPO societario informa prontamente la Direzione Centrale Media e Relazioni Esterne di FS SpA., dandone preventiva informazione al Titolare.

3.5 Fase 5: Post Incident Review

3.5.1 Integrazione Data Breach Report

La fase di *Post Incident Review* è la fase conclusiva di integrazione del *Data Breach Report* e di analisi ex post della violazione.

Le Strutture interessate dalla violazione di sicurezza avviano gli opportuni approfondimenti, al fine di raggiungere la piena consapevolezza sulle cause del *data breach* e individuano le potenziali mitigazioni (*Action Plan*). Entro sessanta giorni, il DPO societario convoca il Gruppo di Lavoro

¹⁴ Il Legislatore Europeo ha indicato le informazioni minimali che devono essere previste nelle notifiche. Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni possono essere fornite in fasi successive senza ulteriore ingiustificato ritardo.

¹⁵ Esempi di metodi trasparenti di comunicazione sono: la messaggistica diretta (ad esempio messaggi di posta elettronica, SMS, messaggio diretto), banner o notifiche su siti web di primo piano, comunicazioni postali e pubblicità di rilievo sulla stampa.

e il DPO di Capogruppo per la chiusura del *Data Breach Report* integrato con le analisi su *root causes*, *lesson learned* e opportunità di miglioramento.

L'implementazione dell'*Action Plan* è responsabilità delle Strutture interessate dalla violazione di sicurezza, mentre spetta al DPO societario, nella sua funzione di controllo, monitorarne l'implementazione.

Il DPO societario provvede alla compilazione del Registro delle Violazioni di Dati Personali e allegando il *Data Breach Report*.

3.5.2 Registro delle Violazioni di Dati Personali

Il Registro delle Violazioni di Dati Personali è il supporto informatico che consente al Titolare di documentare “*qualsiasi violazione dei dati personali, comprese le circostanze a essa relative, le sue conseguenze e i provvedimenti adottati per porvi rimedio.*” (art. 33, par. 5, GDPR). Le informazioni contenute nel Registro sono stabilite dal DPO di Capogruppo, secondo il *template* riportato sulla intranet aziendale.

Scopo del Registro è quello di consentire all'Autorità Garante di verificare, in caso di ispezione o richiesta di specifica, il rispetto degli adempimenti in capo al Titolare nella gestione delle violazioni dei dati personali e fornire un utile strumento per la mitigazione del *data breach* e il seguito delle attività di *Remediation*.

La responsabilità della tenuta e dell'aggiornamento del Registro delle Violazioni di Dati Personali è in capo al DPO societario ed è reso disponibile, in sola consultazione, al DPO di Capogruppo.

Il DPO di Capogruppo, in considerazione del contenuto dei Registri societari, valuta se proporre eventuali azioni di mitigazione coordinate sulle Società del Gruppo FS Italiane.

Il DPO societario provvede, almeno annualmente, ad aggiornare il Registro sulla base dello stato di avanzamento degli interventi previsti nei *Data Breach Report*.